

PeachtreePay GRC Portfolio

Executive summary | ISO/IEC 27001:2022 readiness and third-party vendor risk assessment

15	12	14	19
security risks	readiness areas	selected Annex A controls	evidence types

Purpose and business context

PeachtreePay is a fictional 100-person fintech organization used to demonstrate practical entry-level GRC work. The portfolio translates business context into risk decisions, control assessments, evidence expectations, remediation priorities, and management communication. It is not a real client engagement or certification audit.

Project 1 - ISO 27001 readiness

Defined the ISMS scope and key assets; applied a 5 x 5 risk method; created a 15-item risk register and treatment plan; assessed 12 control areas; documented a selected-control Statement of Applicability; mapped evidence; drafted policy samples; and prioritized a 90-day remediation roadmap.

Project 2 - Third-party risk

Assessed the simulated CloudBridge CRM vendor through questionnaire review, evidence analysis, vendor-risk scoring, remediation planning, and an executive conditional-approval recommendation.

Key findings

Risk profile: 1 Critical, 13 High, and 1 Medium inherent risk.

Readiness: 5 control areas Not Implemented and 7 Partial.

Priority exposure: inconsistent MFA creates the only Critical risk (score 20).

Assurance gap: planned controls require evidence review and operating-effectiveness testing before residual risk is accepted.

Management recommendation

Prioritize company-wide MFA, formal HR-to-IT offboarding, and vulnerability-remediation timelines in the first 30 days. Require accountable owners, dated evidence, documented testing, and residual-risk review before closing remediation items.

Decision trail demonstrated: business risk -> inherent score -> treatment -> control alignment -> owner -> evidence -> testing -> residual risk.

Portfolio deliverables

Risk register | gap assessment | risk treatment plan | selected-control SoA | evidence register | policy samples | 90-day roadmap | MFA traceability case study | MFA control-testing workpaper | cross-framework mapping | vendor questionnaire | evidence review | vendor risk register | remediation plan | executive risk memo

Candidate value

This portfolio demonstrates risk-based judgment, audit-oriented evidence thinking, cross-framework awareness, clear written communication, and the ability to connect governance requirements to practical security and business decisions.